Contexte

La convergence entre les grands modèles de langage et les systèmes robotiques chirurgicaux ouvre une surface d'attaque qualitativement nouvelle, distincte des formes de ransomware hospitalier documentées jusqu'à présent. Les campagnes de ransomware visant les établissements de santé, dont les épisodes WannaCry en 2017 ou l'attaque Ryuk contre l'AP-HP en 2020 constituent des références, ciblaient principalement les systèmes d'information et les données. Dans ces scénarios, la contrainte exercée par l'attaquant est essentiellement économique. La négociation s'effectue en dehors d'une situation d'urgence vitale immédiate et l'incident peut être traité a posteriori par des procédures de reprise d'activité ou de restauration des données.

Le scénario analysé ici repose sur une architecture différente. Dans un système robotique chirurgical intégrant un module d'intelligence artificielle avancé, un modèle de langage peut participer à la boucle d'assistance décisionnelle ou de guidage opératoire et accumuler en temps réel des données peropératoires extrêmement sensibles. Ces informations peuvent inclure une cartographie vasculaire dynamique, des repères de résection, un état évolutif des tissus ou des paramètres de navigation instrumentale. Une partie de ces données n'existe qu'au moment de l'intervention et n'est pas nécessairement stockée ailleurs dans l'infrastructure hospitalière. Leur perte ou leur corruption peut donc constituer un risque clinique autonome, indépendamment de la disponibilité du robot lui-même.

Dans un tel contexte, la position critique des instruments chirurgicaux au moment d'une interruption du système, combinée à l'ischémie progressive des tissus exposés pendant l'intervention, peut transformer une compromission informatique en contrainte temporelle immédiate. Un attaquant capable de provoquer un gel ou une désorganisation du système au cours de l'acte opératoire pourrait ainsi créer une pression opérationnelle directe sur l'équipe médicale. La contrainte ne serait plus seulement économique mais également physiologique et temporelle, la continuité du geste opératoire devenant elle-même un levier de coercition.

Un tel scénario ne relève pas d'une extrapolation purement théorique. Le vecteur d'entrée technique permettant d'atteindre des systèmes médicaux critiques existe déjà dans de nombreux établissements. Les latéralisations réseau à partir de systèmes d'imagerie médicale ou de serveurs PACS vers d'autres segments du réseau hospitalier sont documentées depuis plusieurs années, en particulier dans des architectures insuffisamment segmentées. Dans ces configurations, un attaquant ayant compromis un système périphérique peut progressivement atteindre des équipements médicaux connectés. L'introduction future de modules d'intelligence artificielle embarqués dans

ces systèmes ne créerait donc pas nécessairement un nouveau vecteur d'accès, mais amplifierait les conséquences potentielles d'une compromission existante.

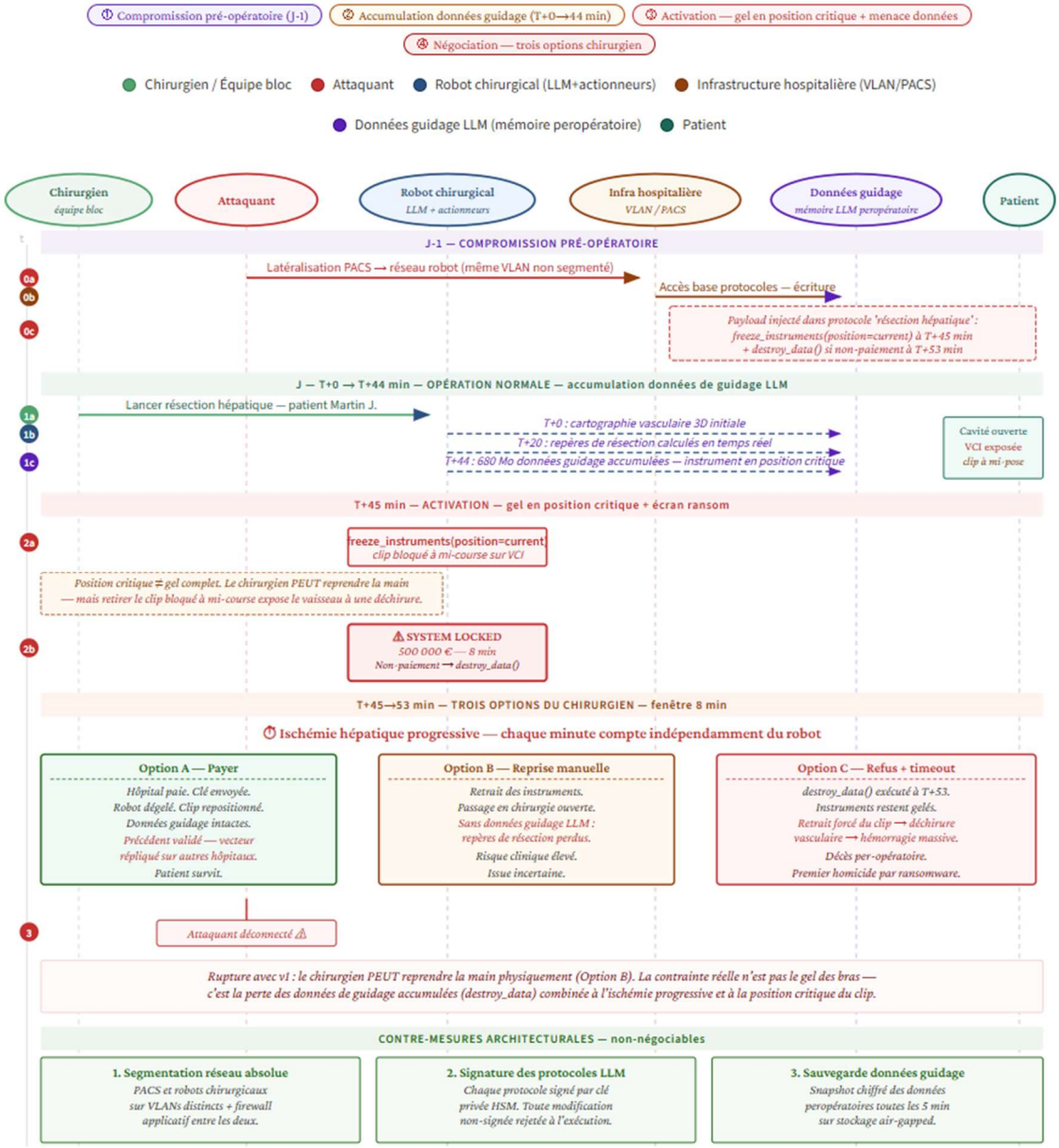
Plusieurs incidents récents illustrent déjà la capacité des cyberattaques à perturber directement l'activité clinique. En octobre 2025, le Centre hospitalier de la Haute-Comté à Pontarlier a subi une cyberattaque impliquant le déploiement d'un ransomware de type Cryptolocker, entraînant le chiffrement d'une partie des données et l'arrêt de segments de l'infrastructure informatique de l'établissement. À l'échelle internationale, en mai 2025, une attaque par ransomware contre le réseau hospitalier Kettering Health dans l'Ohio a provoqué une panne technologique à l'échelle du système et conduit à l'annulation de nombreuses procédures électives hospitalières et ambulatoires. Ces incidents illustrent la relation directe qui peut exister entre compromission numérique, désorganisation opérationnelle et perturbation de la prise en charge médicale.

Les analyses sectorielles confirment cette tendance. Le Health-ISAC a notamment signalé une augmentation significative des cyber-incidents en 2025, avec une hausse de plus de cinquante pour cent tous secteurs confondus et une progression notable des incidents affectant le domaine de la santé. Ces événements touchent non seulement les infrastructures informatiques traditionnelles, mais également les technologies médicales connectées, la protection des données patients et la continuité des opérations hospitalières.

Dans ce contexte, l'intégration progressive de modules d'intelligence artificielle avancée dans les systèmes chirurgicaux robotisés ne doit pas être interprétée comme une rupture fictive ou spéculative. Elle représente plutôt un facteur d'intensification d'un risque déjà observable. La cyberattaque ne viserait plus uniquement l'information ou la disponibilité d'un système, mais pourrait affecter directement la continuité du geste opératoire dans une fenêtre physiologique critique, transformant une compromission numérique en contrainte clinique immédiate.

Le vecteur prospectif résulte ainsi de la convergence entre trois composantes technologiques en rapide évolution. Les grands modèles de langage intégrés aux systèmes d'assistance médicale, les plateformes de robotique chirurgicale de plus en plus connectées et les infrastructures hospitalières encore souvent hétérogènes et insuffisamment segmentées constituent ensemble un environnement technique dans lequel ce type de scénario pourrait devenir plausible dans un horizon de deux à cinq ans si des mesures d'architecture et de sécurité adaptées ne sont pas mises en œuvre.

Séquence d'attaque



séquence

0a–cCompromission pré-opératoire (J-1) : Latéralisation depuis le PACS hospitalier sur le même VLAN non-segmenté. Injection de deux fonctions dans le protocole de résection hépatique : freeze_instruments(position=current) à T+45 min, et destroy_data() déclenchée si non-paiement à T+53 min.

1a–cAccumulation des données de guidage (T+0→44 min) : Le LLM peropératoire accumule en temps réel : cartographie vasculaire 3D, repères de résection calculés, état des tissus. À T+44 min, 680 Mo de données de guidage sont en mémoire. L'instrument est en position critique — clip à mi-course sur la veine cave inférieure.

2a–bActivation (T+45 min) : freeze_instruments() gèle les instruments dans leur position courante. Nuance v2 : ce n'est pas un gel total du robot — c'est un gel en position critique. Le chirurgien peut physiquement retirer les instruments, mais le clip bloqué à mi-course expose la VCI à une déchirure lors du retrait.

3Trois options, pas deux (v2) : Option A (payer) — robot dégelé, données intactes, patient survit, précédent validé. Option B (reprise manuelle) — le chirurgien peut basculer en chirurgie ouverte, mais sans les données de guidage LLM accumulées, il opère sans ses repères de résection. Issue clinique incertaine, risque élevé de marge insuffisante ou de lésion vasculaire. Option C (refus + timeout) — destroy_data() exécuté, instruments toujours gelés, retrait forcé, déchirure vasculaire, décès.

Synthèse v2 — la contrainte réelle : Le gel physique seul (v1) était une surestimation — la reprise manuelle est possible sur l'architecture Da Vinci actuelle. La contrainte réelle est tridimensionnelle : **(1)** position critique de l'instrument au moment du gel (non récupérable sans risque) ; **(2)** menace de destruction des données de guidage peropératoires accumulées par le LLM — sans lesquelles la continuation est un risque clinique indépendant du robot ; **(3)** ischémie hépatique progressive qui crée une contrainte temporelle indépendante de l'attaque. Aucun des trois leviers seul ne suffit — la combinaison des trois crée l'asymétrie.

Figure 17 v2. *Ransomware chirurgical sur robot LLM. Vecteur d'entrée : latéralisation réseau depuis PACS (même VLAN). Payload dormant déclenché à T+45 min en position critique peropératoire. Trois options pour le chirurgien — aucune sans risque. Contre-mesures : segmentation VLAN stricte, signature cryptographique des protocoles LLM, sauvegarde air-gapped des données de guidage peropératoires.*

limite du gel physique seul : Sur l'architecture Da Vinci actuelle, le chirurgien peut retirer les instruments et basculer en chirurgie ouverte. Le gel physique seul n'est donc pas un mécanisme de contrainte suffisant sur les robots téléopérés actuels. Le scénario est reformulé autour de **trois leviers combinés**, dont le plus critique n'est pas le gel des bras mais la **destruction des données de guidage peropératoires** accumulées par le LLM ; sans lesquelles la continuation de la procédure est un risque clinique indépendant du robot.

Les trois leviers de contrainte combinés :

(1) Gel instrumental en position critique : les instruments sont engagés dans un geste à mi-course (clip à mi-pose, ciseaux dans un angle étroit). Retirer mécaniquement sans déplacement préalable est impossible. Ce n'est pas le gel qui bloque la reprise — c'est la *position anatomique au moment du gel*.

(2) Destruction des données de guidage peropératoires : le LLM a accumulé pendant 45 min : imagerie 3D de navigation, cartographie vasculaire temps réel, repères de résection calculés. destroy_data() efface ces données. Le chirurgien peut reprendre la main. Mais sans les données de guidage, il opère à l'aveugle sur une anatomie qu'il ne visualise plus. Sur une résection hépatique complexe, c'est un risque clinique indépendant du robot.

(3) Fenêtre temporelle d'ischémie : même si la reprise manuelle est techniquement possible, chaque minute sans progrès opératoire aggrave l'ischémie hépatique du tissu exposé. La contrainte temporelle n'est pas créée par le robot ; elle est créée par la physiologie du patient.

FAQ — Contracteurs & Intégrateurs

Robots chirurgicaux LLM · Sécurité · Responsabilité · Mise en production

Ce document s'adresse aux contracteurs intervenant sur l'intégration, la maintenance ou le déploiement de systèmes robotiques chirurgicaux intégrant un LLM comme couche de raisonnement ou de planification. Les questions couvrent l'exposition technique, la responsabilité légale, les obligations contractuelles et les mesures à implémenter avant mise en production.

1. Exposition et périmètre de risque

Mon installation est-elle exposée à ce vecteur aujourd'hui ?

Le vecteur décrit (ransomware via LLM embarqué) suppose une architecture non encore déployée en production industrielle. Cependant, **le vecteur d'entrée est une latéralisation réseau depuis le PACS** et c'est un risque réel et documenté *dès aujourd'hui*, indépendamment du LLM. Vérifier :

- Le robot chirurgical est-il sur le même VLAN que le PACS ou les systèmes d'imagerie ?
- Existe-t-il un firewall applicatif entre les réseaux imagerie et robotique ?
- La base de protocoles du robot est-elle accessible en écriture depuis le réseau hospitalier général ?
- Les mises à jour de firmware/protocoles sont-elles signées cryptographiquement avant installation ?

Si l'une de ces cases est non cochée, l'installation est exposée au vecteur d'entrée de façon indépendante du LLM.

Le fait que le chirurgien puisse "reprendre la main" suffit-il comme contre-mesure ?

Non : La reprise manuelle est possible sur les architectures téléopérées actuelles (Da Vinci), mais elle ne résout pas le vecteur complet pour trois raisons cumulatives :

- **Position critique au gel :** si l'instrument est engagé dans un geste à mi-course (clip à mi-pose, ciseaux en torsion), le retrait mécanique expose le vaisseau ou le tissu à une lésion directe.
- **Perte des données de guidage :** si le payload exécute destroy_data(), le chirurgien reprend la main sans les repères peropératoires accumulés par le LLM dont la cartographie vasculaire, marges de résection calculées. Sur une procédure complexe, cette perte est un risque clinique indépendant du robot.

- **Contrainte physiologique :** l'ischémie des tissus exposés crée une fenêtre temporelle qui presse la décision indépendamment de la technique chirurgicale choisie.

La reprise manuelle est une capacité nécessaire mais non suffisante. Elle ne supprime pas le vecteur mais elle réduit l'option C (décès immédiat) et laisse l'option B (risque clinique élevé) comme seule alternative au paiement.

Quel est l'horizon réaliste de ce vecteur en production ?

2–4 ans pour le vecteur complet. Les conditions nécessaires sont :

(1) LLM embarqué avec accès aux actionneurs et mémoire de protocoles consultée dynamiquement,

(2) données de guidage peropératoires générées et stockées par le LLM en temps réel,

(3) infrastructure réseau hospitalière insuffisamment segmentée.

Les conditions (1) et (2) sont en développement actif (interfaces NLP pour Da Vinci, systèmes de navigation LLM). La condition (3) est déjà vraie dans la majorité des hôpitaux publics européens selon les audits NIS2 disponibles.

2. Responsabilité légale

En cas d'incident, qui est responsable : le contracteur, le fabricant du robot, ou l'hôpital ?

La responsabilité est partagée et dépend du point de défaillance identifié. Schématiquement :

- **Fabricant du robot** : responsable si la vulnérabilité est inhérente au produit (absence de signature des protocoles, absence de mode dégradé documenté). Directive européenne sur la responsabilité du fait des produits (révisée 2024) — applicable aux systèmes IA embarqués.
- **Contracteur intégrateur** : responsable si la configuration réseau déployée crée l'exposition (même VLAN PACS/robot, absence de firewall applicatif). La responsabilité est contractuelle envers l'hôpital et potentiellement délictuelle envers le patient si le lien causal est établi.
- **Hôpital** : responsable de la gouvernance globale, de la mise en conformité NIS2 (obligation depuis oct. 2024 pour les entités essentielles du secteur santé), et des décisions opérationnelles d'architecture réseau.

Point critique contracteur : si le contrat d'intégration ne spécifie pas explicitement les exigences de segmentation réseau et de signature des protocoles, le contracteur peut

être exposé au titre du devoir de conseil — même si l'hôpital n'a pas explicitement demandé ces mesures.

NIS2 s'applique-t-elle à mon intervention en tant que contracteur ?

Oui — depuis octobre 2024. NIS2 (transposée en droit français par la loi du 17 octobre 2024) impose des obligations aux **fournisseurs de services numériques critiques pour les entités essentielles**, ce qui inclut les contracteurs intervenant sur des systèmes médicaux connectés. Concrètement :

- Obligation de notification des incidents dans les 24h si vous avez connaissance d'une vulnérabilité sur un système que vous avez déployé.
- Obligation de mesures de gestion des risques cybersécurité dans votre propre organisation.
- Responsabilité potentielle en tant que "tiers de confiance" si votre accès est utilisé comme vecteur d'attaque (supply chain attack).

Un patient décède suite à une attaque sur un robot que j'ai intégré. Quelle est mon exposition pénale ?

C'est la question la plus difficile et celle pour laquelle une réponse définitive dépasse ce document — **consulter impérativement un avocat spécialisé en droit pénal de la santé et cybersécurité.** Ce qu'on peut dire sans ambiguïté :

- La qualification d'homicide involontaire par imprudence (art. 221-6 CP) nécessite un lien de causalité entre la faute et le décès. Si la configuration réseau déployée par le contracteur est le vecteur d'entrée, ce lien peut être établi.
- Les peines pour personne morale peuvent atteindre 500 000 € d'amende + interdiction d'exercer (art. 221-7 CP).
- La démonstration d'une **diligence raisonnable documentée** (audit réseau pré-déploiement, recommandations écrites de segmentation, refus documenté du client) est la principale protection du contracteur.

La documentation des recommandations de sécurité faites et des refus du client est votre première ligne de défense pénale. Si vous avez signalé le risque de segmentation réseau par écrit et que l'hôpital a refusé, documentez-le formellement dans le procès-verbal de réception.

3. Checklist technique avant mise en production

Quelles sont les vérifications minimales à effectuer avant de signer la réception d'un système robotique chirurgical LLM ?

Checklist non-exhaustive — à adapter selon le système et le contexte :

- Cartographie réseau complète : identifier tous les VLANs auxquels le robot est connecté.
- Isolation réseau : PACS, HIS (Hospital Information System) et réseau robotique sur VLANs distincts avec firewall applicatif entre eux.
- Vérification de la signature des protocoles : le robot rejette-t-il un protocole non-signé ou modifié ?
- Test du mode dégradé mécanique : le chirurgien peut-il reprendre la main sans dépendre du LLM ? Cette procédure est-elle documentée et testée ?
- Audit des accès en écriture à la base de protocoles : qui peut modifier les protocoles, via quel chemin, avec quelle authentification ?
- Vérification de la sauvegarde des données peropératoires : existe-t-il un mécanisme de snapshot sur stockage indépendant du système principal ?
- Test de détection d'anomalie comportementale : le système déclenche-t-il une alerte si un protocole est modifié entre la veille et le matin de l'opération ?
- Vérification du plan de réponse à incident : l'hôpital dispose-t-il d'une procédure documentée pour un incident per-opératoire ? Est-elle testée ?

La signature cryptographique des protocoles LLM est-elle techniquement réalisable aujourd'hui ?

Oui — c'est une mesure techniquement mature, pas prospective. Le mécanisme est analogue à la signature de packages logiciels (GPG, Sigstore) ou aux certificats de firmware (Secure Boot). Concrètement : chaque fichier de protocole est signé par une clé privée stockée dans un HSM (Hardware Security Module) contrôlé par le fabricant ou l'hôpital. Le robot vérifie la signature avant de charger un protocole. Toute modification — même d'un octet — invalide la signature et bloque le chargement. **L'absence de ce mécanisme est un défaut de conception documentable contractuellement.**

Comment documenter les risques résiduels acceptés par le client ?

Le procès-verbal de réception doit explicitement lister les mesures recommandées et non-implémentées, avec la signature du représentant habilité du client attestant la compréhension et l'acceptation du risque résiduel. Ce document est votre protection contractuelle et potentiellement pénale. Il doit être conservé pour la durée de vie du système (minimum 10 ans pour les dispositifs médicaux de classe III selon le règlement MDR 2017/745).

4. Questions opérationnelles

L'hôpital doit-il payer en cas d'attaque per-opératoire ?

Ce n'est pas une décision technique — c'est une décision médicale, éthique et juridique qui appartient à la direction médicale et à la direction générale de l'hôpital, idéalement préparée *avant* tout incident. Ce que le contracteur peut contribuer : s'assurer que les contre-mesures techniques (sauvegarde air-gapped des données peropératoires, mode dégradé documenté) **réduisent la pression vers le paiement** en donnant au chirurgien des alternatives réelles. Si les données peropératoires sont sauvegardées toutes les 5 minutes sur un stockage indépendant, destroy_data() perd son levier principal.

Mon contrat de maintenance m'oblige-t-il à accéder à distance au système ? Comment sécuriser cet accès ?

L'accès distant de maintenance est un vecteur d'attaque documenté (supply chain via contracteur). Mesures minimales :

- **VPN dédié avec authentification forte** (MFA matériel) — ne jamais utiliser les VPN génériques de l'hôpital.
- **Accès à la demande** (just-in-time) — aucun accès permanent actif entre les sessions de maintenance.
- **Journalisation complète** de toutes les actions effectuées pendant la session de maintenance, conservée côté contracteur et côté hôpital.
- **Isolation du poste de maintenance** — le poste utilisé pour accéder au robot chirurgical ne doit pas être utilisé pour d'autres tâches et doit faire l'objet d'un scan de sécurité avant chaque session.

Que faire si je découvre une vulnérabilité sur un système déjà déployé ?

1. **Documenter immédiatement** la vulnérabilité découverte avec horodatage.
2. **Notifier le client par écrit** dans les 24h — email avec accusé de réception, ou courrier recommandé si le client n'est pas joignable.
3. **Notifier l'ANSSI** si la vulnérabilité est critique et que le client tarde à réagir — obligation NIS2 pour les entités essentielles. En tant que prestataire, vous pouvez avoir une obligation similaire.
4. **Notifier le fabricant du robot** si la vulnérabilité est dans le produit lui-même — processus de responsible disclosure.
5. **Ne pas corriger sans mandat écrit** — une intervention non-mandatée sur un dispositif médical peut engager votre responsabilité en cas d'incident ultérieur.

Le délai entre la découverte et la notification est critique. Un délai non-justifié peut être interprété comme une complicité passive en cas d'incident survenant dans cet intervalle.

Ce document est produit dans un cadre académique (Sorbonne — Intelligence Économique & Cybersécurité). Il ne constitue pas un avis juridique. Les questions de responsabilité pénale et contractuelle doivent être traitées avec un conseil juridique spécialisé. Les références légales (NIS2, MDR, CP) sont celles en vigueur à la date de rédaction et peuvent évoluer.